

Kunden-CRM

Anwendung · Version 1.0 · Abgeschlossen · zuletzt bearbeitet am 30.09.2026 · abgeschlossen am 30.09.2026 von Anna Beispiel

Ergebnis

Vertraulichkeit (Confidentiality) Hoch Maximum aller Szenarien	Integrität (Integrity) Normal Maximum aller Szenarien	Verfügbarkeit (Availability) Sehr hoch Maximum aller Szenarien
--	---	--

Bewertung je Schadensszenario

Schadensszenario	Vertraulichkeit Confidentiality	Integrität Integrity	Verfügbarkeit Availability
Gesetze & Verträge	Hoch	Normal	Normal
Selbstbestimmung / DSGVO	Hoch	Normal	Normal
Leib & Leben	n. r.	Normal	Normal
Aufgabenerfüllung	Normal	Normal	Sehr hoch
Innen-/Außenwirkung	Normal	Normal	Normal
Finanzielle Auswirkungen	Normal	Normal	Normal

n. r. = für diesen Grundwert nicht relevant · offen = noch nicht bewertet

Stammdaten

Asset-Bezeichnung Kunden-CRM	Asset-Typ Anwendung
Asset-Owner Leitung Vertrieb	Verantwortliche Organisationseinheit —
Kontakt —	Ersteller:in Informationssicherheit
Standort —	Personenbezogene Daten Ja
Besondere Kategorien personenbezogener Daten nicht angegeben	
Beschreibung / Einsatzzweck —	
Geltungsbereich Produktivsystem inkl. Schnittstellen zu ERP und Newsletter-Dienst	

Begründung je Grundwert

Vertraulichkeit (Confidentiality)

 Hoch

Begründung

Umfangreiche personenbezogene Kundendaten mit vertraglichen Vertraulichkeitspflichten.

Szenarien mit erhöhtem Schutzbedarf

Verstoß gegen Gesetze, Vorschriften und Verträge

 Hoch

Vertraulichkeitsvereinbarungen mit Großkunden sehen Vertragsstrafen vor.

Kriterium

Falls ja, führt die Kenntnisnahme der Informationen durch Unbefugte zu erheblichen Verstößen gegen diese Regelungen und damit zu erheblichen juristischen Konsequenzen / Vertragsstrafen.

Beeinträchtigung des informationellen Selbstbestimmungsrechts

 Hoch

Kontakt- und Vertragsdaten von ca. 120.000 Kund:innen; Meldepflicht nach Art. 33 DSGVO.

Kriterium

Falls ja, hat die Kenntnisnahme der personenbezogenen Daten durch Unbefugte erhebliche Auswirkungen auf die Betroffenen und kann diese in ihrer gesellschaftlichen Stellung oder ihren wirtschaftlichen Verhältnissen erheblich beeinträchtigen.

Integrität (Integrity)

 Normal

Alle 6 Szenarien „Normal“ oder nicht zutreffend. Eine Begründung ist bei „Normal“ nicht erforderlich.

Verfügbarkeit (Availability)

 Sehr hoch

Begründung

Kernprozess Kundenservice ist vollständig vom CRM abhängig (RTO <= 1 h).

Szenarien mit erhöhtem Schutzbedarf

Beeinträchtigung der Aufgabenerfüllung

 Sehr hoch

Der Kundenservice arbeitet ausschließlich im CRM; tolerierbar ist höchstens eine Stunde.

Kriterium

Falls ja, hat die Nichtverfügbarkeit der Informationen fundamentale Auswirkungen auf die Aufgabenerfüllung und kann nur bis zu einer Dauer von 1 Stunde von den Betroffenen toleriert werden.

Nächste Schritte

1. Risikoanalyse durchführen – kopexa.com/de/glossary/risikoanalyse
2. Maßnahmen festlegen und Controls zuordnen – kopexa.com/de/catalog/iso-27001/controls
3. Business-Impact-Analyse durchführen – kopexa.com/de/glossary/business-impact-analysis-bia
4. Abhängige Systeme bewerten – kopexa.com/de/glossary/maximumpinzip
5. Datenschutz-Folgenabschätzung prüfen
6. Regelmäßig überprüfen – kopexa.com/de/glossary/schutzbedarfsfeststellung

Empfohlene Maßnahmen

Vertraulichkeit, Hoch

- Rollenbasierte Zugriffskontrolle nach Need-to-know, regelmäßige Rezertifizierung der Berechtigungen
- Multi-Faktor-Authentisierung für alle Zugänge
- Verschlüsselung bei Übertragung (TLS 1.2+) und Speicherung
- Protokollierung und Auswertung von Zugriffen

Verfügbarkeit, Sehr hoch

- Datensicherung nach 3-2-1-1-0-Regel (3 Kopien, 2 Medien, 1 extern, 1 offline oder unveränderlich, 0 Fehler beim Wiederherstellungstest), dokumentiertes RTO/RPO
- Monitoring und Alarmierung
- Notfallhandbuch und Wiederanlaufplan
- Redundante, georedundante Auslegung ohne Single Point of Failure
- Regelmäßige Notfall- und Wiederanlaufübungen (BCM nach BSI 200-4)
- DDoS-Schutz und Ransomware-resiliente, isolierte Sicherungen

Empfehlungen zur Ableitung im ISMS; sie ersetzen keine Modellierung nach IT-Grundschutz-Kompendium.

Freigabe

Mit ihrer Unterschrift bestätigen die Beteiligten, dass die Schutzbedarfsfeststellung für „Kunden-CRM“, Version 1.0, vollständig ist und die Einstufungen nachvollziehbar begründet sind.

Prüfsumme dieser Version: 503AEBA0 394BD46E F8918C0F 7DE8C213 E7A721DD 9AEE4263 A6181574 E363E237

Vertraulichkeit

 **Hoch**

Integrität

 **Normal**

Verfügbarkeit

 **Sehr hoch**

Erstellt

Ersteller:in der Analyse

Anna Beispiel

Name

Funktion

30.09.2026

Ort, Datum

Unterschrift

Geprüft

z. B. Informationssicherheitsbeauftragte:r, Datenschutzbeauftragte:r

Name

Funktion

Ort, Datum

Unterschrift

Freigegeben

z. B. Asset-Owner, CISO oder Geschäftsleitung

Name

Funktion

Ort, Datum

Unterschrift

Anhang

Änderungshistorie

Version	Datum	Beschreibung	Bearbeitet von	Status
1.0	30.09.2026	Ersterstellung	Anna Beispiel	Abgeschlossen

Methode

Der Schutzbedarf wird je Grundwert (Vertraulichkeit, Integrität, Verfügbarkeit) anhand standardisierter Schadensszenarien nach BSI-Standard 200-2 bzw. ISO/IEC 27001 ermittelt. Es gilt das Maximumprinzip: Der Schutzbedarf eines Grundwerts entspricht dem höchsten Einzelschaden. Kumulations-, Verteilungs- und Vererbungseffekte werden als begründete Übersteuerung dokumentiert.

Bewertungsschema: Standard (Referenzbogen) (Stand 1): Finanzieller Schaden hoch ab 1.000.000 €, sehr hoch ab 10.000.000 €; tolerierbarer Ausfall hoch bis 24 Stunden, sehr hoch bis 1 Stunde.

Versions-ID e246a41b-8163-46c9-8155-ab1ec5df91d2

Prüfsumme

Jede Seite trägt die Kurzform der Prüfsumme. Sie wird als SHA-256 über den Inhalt dieser Version berechnet; Seiten einer anderen Version oder eines anderen Dokuments zeigen einen anderen Wert. Zum Prüfen die Analyse in der Schutzbedarfsanalyse öffnen: Die Historie zeigt dieselbe Prüfsumme je Version.

503AEBA0 394BD46E F8918C0F 7DE8C213 E7A721DD 9AEE4263 A6181574 E363E237

Hinweise

Erstellt mit der Kopexa Schutzbedarfsanalyse (schutzbedarf.kopexa.com), einem kostenlosen Hilfsmittel ohne Gewähr. Sie ersetzt keine Rechts-, Datenschutz- oder Auditberatung; Einstufung, Begründung und abgeleitete Maßnahmen verantwortet die anwendende Organisation.



kopexa.com